UNIPÊ · Centro Universitário de João Pessoa
Análise e Projeto de Sistemas · Projeto Final · 2026.2

Rufus Bank

"Rufus, iluminando sua vida financeira"

Documento de Apoio (AID) · Da Concepção ao Dia 1 do Dev

Integrante	Papel
Pedro Oliveira	Analista / PO
Izaias Terto	Arquiteto de Software
Carlos Eduardo	Engenheiro / DBA

Professor: Israel Cunha · 04/11/2026

Sumário

Bloco 1 · Concepção e Escopo 3

1. Documento de Visão 3
2. Personas 6
3. Mapa de Stakeholders 8
4. Estudo de Viabilidade 10

Custo mensal de infraestrutura (gerado) 13

5. Riscos iniciais 15

Bloco 2 · Requisitos 17

2.1 Requisitos Funcionais 17
2.2 Requisitos Não Funcionais 20
2.3 Histórias de Usuário 22

Bloco 3 · Arquitetura de Software 28

3.1 Architecture Decision Records (ADR) 28
3.3 Stack tecnológica 34
3.4 Padrões de design 36
3.5 Modelo de domínio (fonte única) 38
3.6 Rotas da API (fonte única) 43

Bloco 1 · Concepção e Escopo

1. Documento de Visão

Nome e slogan

Nome	**Rufus Bank**
Slogan	**"Rufus, iluminando sua vida financeira"**
Domínio	Fintech: conta digital, pagamentos e controle financeiro

Problema real

Bancos digitais têm interfaces complexas, cheias de jargão e com menus escondidos. Isso exclui quem tem pouca leitura, pouca familiaridade com tecnologia ou com finanças. O problema hoje não é ter conta: é conseguir usar a conta sozinho e com segurança.

Os dados mostram isso:

Dado	Número	Fonte
Adultos que não usaram nenhum produto financeiro em 2024 (nem Pix, nem boleto, nem crédito)	21,1 milhões (11,6% dos adultos). Predominam idosos e pessoas sem emprego formal	Banco Central, Relatório de Cidadania Financeira 2025, seção 1.1
Acerto médio nas perguntas de conhecimento financeiro	53%. O Brasil fica em 33º lugar, abaixo da média mundial	Idem, seção 1.2 (pesquisa OCDE/INFE de 2023)
Pessoas que erraram uma conta simples de juros	87%	Idem, seção 1.2
Relação do letramento financeiro com idade e escolaridade	Cai com a idade e sobe com a escolaridade	Idem, seção 1.2
Idosos (60+) que usam internet	59%, contra 43% em 2022	Idem, citando a TIC Domicílios 2024
Analfabetos funcionais (15 a 64 anos)	29%. Na faixa de 50 a 64 anos, 51%	Inaf 2024, divulgado em 05/05/2025
Analfabetos funcionais que usam internet	73%, mas 60% deles estão no nível mais baixo de habilidade digital	Idem
Golpe da falsa central ou falso funcionário de banco	139 mil relatos no 1º semestre de 2025, alta de 195,7% sobre 2024	Febraban, divulgado em 11/11/2025

Leitura dos dados: quase todo mundo já tem acesso, mas uma parte grande da população lê com dificuldade, entende pouco de juros e é alvo de golpes. São exatamente as pessoas que os apps atuais atendem mal.

Proposta de valor

Um banco digital com interface simples, linguagem clara e foco em quem os bancos tradicionais atendem mal.

Na prática, isso vira cinco princípios que valem para todas as telas e que os próximos blocos precisam cumprir:

1. **Ícone e áudio em toda tela.** Tudo que está escrito pode ser ouvido. Quem não lê bem não fica de fora.
2. **Poucos passos.** As ações principais (ver saldo, mandar Pix, pagar conta) terminam em no máximo 3 toques depois do login.
3. **Linguagem do dia a dia.** Frases curtas, sem jargão. "Dinheiro que você tem" no lugar de "saldo disponível".
4. **Proteção contra golpe por padrão.** O Rufus nunca liga para o cliente. Antes de mandar dinheiro, o app fala em voz alta para quem vai e quanto.
5. **Autonomia com rede de apoio.** O cliente usa sozinho, mas pode ter um contato de confiança e, no caso de menor de idade, um responsável vinculado.

Público-alvo

Adultos com baixa escolaridade ou pouca familiaridade digital, idosos e adolescentes de 16 e 17 anos com renda própria. As três personas do item 2 representam esses grupos.

Atores do sistema

O enunciado pede no mínimo 4 atores. O Rufus tem 6 humanos e 3 sistemas externos:

Ator	Tipo	O que faz
Cliente titular	Humano	Usa a conta: saldo, Pix, contas, metas
Cliente menor (16 e 17 anos)	Humano	Usa a conta dentro dos limites aprovados pelo responsável
Responsável legal	Humano	Autoriza a conta do menor, define limites e aprova pedidos
Contato de confiança	Humano	Recebe aviso de movimentação fora do padrão (familiar ou cuidador)
Atendente do SAC	Humano	Atende chamados abertos dentro do app
Analista antifraude	Humano	Analisa transações suspeitas e bloqueia contas
Parceiro BaaS	Sistema externo	Instituição autorizada pelo Banco Central que mantém a conta e liquida o Pix
Serviço de voz	Sistema externo	Transforma texto em fala (Amazon Polly)
Serviço de notificação	Sistema externo	Envia push e SMS

Funcionalidades macro

O enunciado pede no mínimo 12. São 16, que o Bloco 2 detalha em requisitos com MoSCoW:

#	Funcionalidade	Persona que mais precisa
F01	Abertura de conta guiada por voz, com foto do documento e selfie	Antônio, Dona Marlene
F02	Entrada no app por biometria do celular ou senha de 6 números	Todas
F03	Saldo e extrato com ícones e leitura em voz alta	Antônio, Dona Marlene
F04	Enviar Pix por contato, chave ou QR Code, com confirmação falada	Todas
F05	Receber Pix por QR Code ou chave	Antônio
F06	Pagar boleto e contas de consumo apontando a câmera	Dona Marlene
F07	Conta de menor vinculada ao responsável	Camila
F08	Limites e pedidos de aprovação ao responsável	Camila
F09	Metas de economia com progresso em imagem ("cofrinho")	Camila
F10	Contato de confiança, avisado em movimentação fora do padrão	Dona Marlene

#	Funcionalidade	Persona que mais precisa
F11	Alertas contra golpe e botão "bloquear tudo agora"	Todas
F12	Lembrete de conta a vencer	Dona Marlene
F13	Dicas curtas de educação financeira em áudio	Camila, Antônio
F14	Atendimento humano iniciado só de dentro do app	Todas
F15	Painel antifraude para análise de transações suspeitas	Analista antifraude
F16	Painel do SAC com histórico do cliente	Atendente do SAC

Fora do escopo

Fora do escopo	Por quê
Atendimento presencial (agências, postos)	O produto é 100% digital. O atendimento humano existe, mas dentro do app (F14)
Crédito, empréstimo e cartão de crédito	Endividamento é um risco alto para o público-alvo, e crédito exige outra regulação. Fica para uma fase futura
Investimentos	Exige outra autorização e outro nível de letramento. Fica para uma fase futura
Conta para empresa (PJ ou MEI)	O público é pessoa física
Cartão físico e saque em dinheiro	Dependem de logística e de rede de terceiros. O MVP fica no Pix e no boleto
Câmbio, conta em outra moeda e criptoativos	Fora do problema que o projeto resolve
Versão web completa para o cliente	O público usa celular. Na web existe só o site institucional e os painéis internos (F15 e F16)
Core bancário próprio	A conta e a liquidação ficam com o parceiro BaaS (ver item 4)

2. Personas

Três personas, uma para cada grupo que os bancos atuais atendem mal: baixa leitura, menor de idade e idoso. Cada uma aponta para funcionalidades do Documento de Visão (F01 a F16).

Antônio, 47 anos

Profissão	Ajudante de pedreiro, recebe por diária
Escolaridade	Estudou até o 5º ano. Lê com dificuldade
Celular	Android de entrada, usa WhatsApp e áudio
Como lida com dinheiro hoje	Recebe em dinheiro vivo ou pelo cartão de um parente
O que já deu errado	Foi enganado por um golpista que se passou por atendente do banco
Dores	Tem vergonha de pedir ajuda. Textos longos o fazem desistir. Depende de outra pessoa para receber o próprio pagamento
Motivação	Ter uma conta própria que consiga usar por ícones, áudio e poucos passos, sem depender de ler textos longos nem de ninguém
O que o Rufus entrega	Abertura guiada por voz (F01), receber diária por QR Code (F05), saldo falado (F03), confirmação falada antes do Pix (F04), aviso de que o Rufus nunca liga (F11)

> "Eu só quero ver quanto eu tenho e mandar pro mercado sem pedir pra ninguém ler pra mim."

Camila, 17 anos

Profissão	Estudante do ensino médio e jovem aprendiz (contrato da Lei 10.097/2000)
Renda	Um salário pequeno de aprendiz
Celular	Usa bem, nativa digital
Objetivo	Juntar dinheiro para comprar um notebook
Situação legal	Menor de 16 a 18 anos precisa ser assistida pelos pais para atos da vida civil, como abrir conta
Dores	Os bancos atuais ou bloqueiam a conta dela ou a tratam como adulta, sem nenhuma educação financeira. Os pais precisam autorizar tudo
Motivação	Ter autonomia dentro de limites seguros, com conta vinculada ao responsável e metas de economia fáceis de entender
O que o Rufus entrega	Conta de menor vinculada (F07), limites e pedidos de aprovação ao responsável (F08), meta "notebook" com progresso em imagem (F09), dicas curtas em áudio (F13)

> "Eu quero decidir o que fazer com o meu dinheiro, mas sem meus pais terem que aprovar cada lanche."

Dona Marlene, 68 anos

Profissão	Aposentada

Celular	Usa só para WhatsApp
Como lida com o banco hoje	Depende do neto para mexer no app do banco
Dores	Tem medo de errar e perder dinheiro. Letra pequena e muitos menus confundem. Tem medo de golpe por telefone
Motivação	Ter autonomia para pagar as próprias contas sem pedir ajuda
O que o Rufus entrega	Pagar conta apontando a câmera (F06), lembrete de conta a vencer (F12), neto como contato de confiança (F10), botão "bloquear tudo agora" (F11), atendimento humano só pelo app (F14)

> "Eu pago minhas contas desde sempre. Só não quero ter que esperar meu neto ter tempo."

Como as personas viram requisito

As dores das três personas se repetem em quatro pontos, e cada ponto vira um requisito não funcional com número no Bloco 2:

Dor em comum	Personas	Vira no Bloco 2
Ler com dificuldade	Antônio, Dona Marlene	Toda tela com leitura em voz alta e texto em nível de leitura simples
Medo de errar	Dona Marlene, Antônio	Confirmação antes de mover dinheiro e desfazer enquanto não confirmado
Medo de golpe	Antônio, Dona Marlene	Regras antifraude e contato de confiança
Autonomia com limite	Camila, Dona Marlene	Papéis de responsável e de contato de confiança com permissões diferentes

3. Mapa de Stakeholders

Os stakeholders foram classificados pela matriz poder x interesse: **poder** é quanto a pessoa ou instituição pode mudar ou barrar o projeto, **interesse** é quanto o resultado a afeta. O quadrante define como o grupo vai se relacionar com cada um.

Tabela

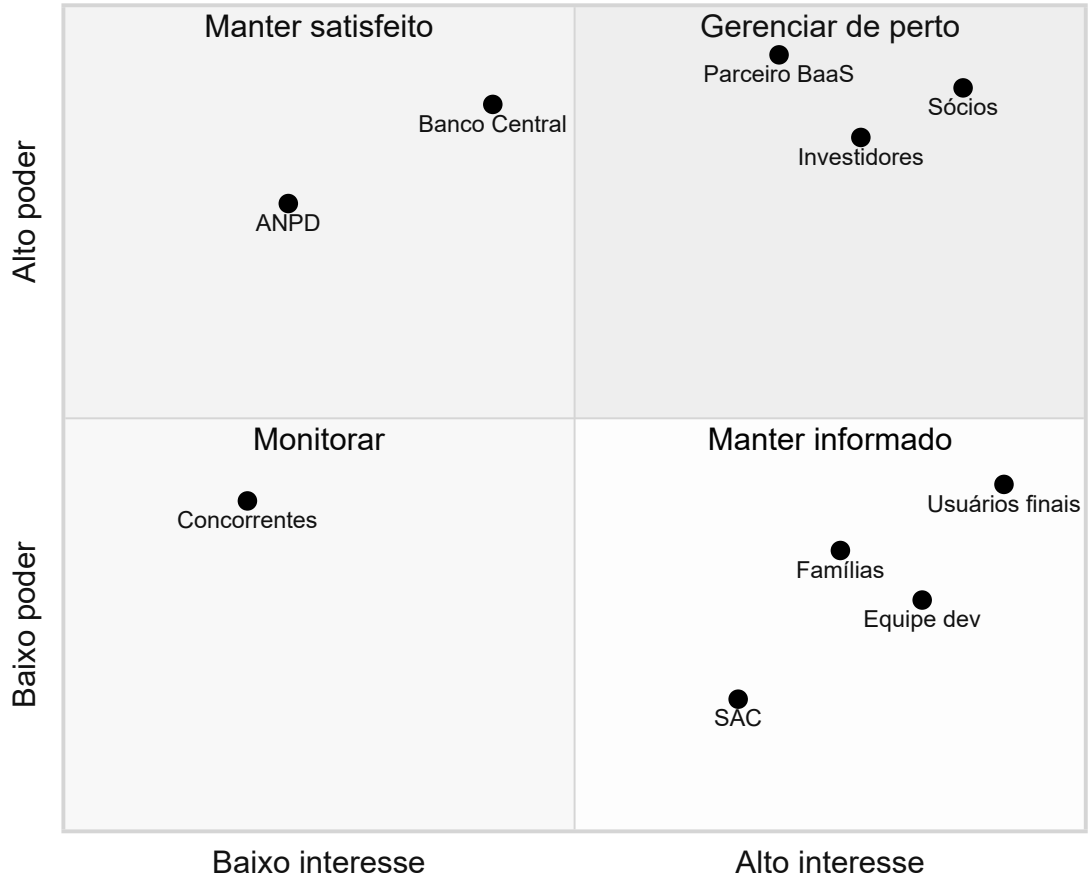
Stakeholder	Tipo	Interesse no projeto	Influência sobre o projeto	Poder	Interesse	Estratégia
Sócios fundadores	Interno	Produto viável, que cresça e dê retorno	Decidem escopo, prioridade e orçamento	Alto	Alto	Gerenciar de perto
Investidores	Externo	Retorno do capital, crescimento da base de clientes	Liberam ou cortam o dinheiro. Cobram metas de adesão e custo	Alto	Alto	Gerenciar de perto
Parceiro BaaS (instituição autorizada)	Externo	Volume de contas e transações com baixo risco de fraude	Sem ele não existe conta nem Pix. Impõe requisitos de segurança e de prevenção à lavagem de dinheiro	Alto	Alto	Gerenciar de perto
Banco Central	Regulador	Inclusão financeira com segurança e sistema estável	Regula o parceiro e o Pix. Uma regra nova pode mudar funcionalidades	Alto	Médio	Manter satisfeito
ANPD	Regulador	Cumprimento da LGPD, com atenção a dados de menores e dados biométricos	Pode fiscalizar e multar. Exige comunicação de incidente	Alto	Baixo	Manter satisfeito
Usuários finais (Antônio, Camila, Dona Marlene)	Externo	Usar a conta sozinhos e sem cair em golpe	Decidem se o produto dá certo: adesão, uso e avaliação nas lojas	Médio	Alto	Manter informado e envolver nos testes
Famílias e cuidadores	Externo	Segurança do parente sem precisar fazer tudo por ele	Indicam ou desaconselham o app. São responsáveis legais e contatos de confiança	Médio	Alto	Manter informado
Equipe de desenvolvimento	Interno	Requisitos claros, prazo realista, stack bem decidida	Define o que é tecnicamente possível e em quanto tempo	Médio	Alto	Manter informado e envolver nas decisões
Equipe do SAC	Interno	Ferramentas para atender rápido e identificar golpe	Traz as reclamações reais. Influencia as melhorias	Baixo	Alto	Manter informado
Concorrentes (bancos e fintechs)	Externo	Manter a base de clientes	Podem copiar a ideia ou baixar preço	Médio	Baixo	Monitorar

O parceiro BaaS não estava na lista inicial do grupo e foi incluído porque o projeto depende dele para existir (ver item 4 e risco R04).

Matriz poder x interesse

Matriz poder x interesse dos stakeholders

Rufus Bank · Autores: Pedro Oliveira, Izaias Terto, Carlos Eduardo · 04/11/2026



Fonte do diagrama: diagramas/stakeholders.mmd.

Os quatro quadrantes, em uma linha cada:

- **Gerenciar de perto** (alto poder, alto interesse): sócios, investidores e parceiro BaaS. Reunião periódica e aprovação das decisões grandes.
- **Manter satisfeito** (alto poder, interesse menor): Banco Central e ANPD. Cumprir as regras e documentar, sem envolver no dia a dia.
- **Manter informado** (poder menor, alto interesse): usuários, famílias, equipe de desenvolvimento e SAC. Testes de uso, comunicação clara e canal de retorno.
- **Monitorar** (poder e interesse menores): concorrentes. Acompanhar lançamentos e preços.

4. Estudo de Viabilidade

Veredito: o projeto é viável. Tecnicamente, tudo que o Rufus precisa já existe em serviços maduros. Operacionalmente, a condição é ter um parceiro autorizado pelo Banco Central. A infraestrutura custa cerca de **R$ 4.426 por mês** (produção e homologação), o que dá R$ 0,33 por usuário ativo em produção.

4.1 Viabilidade técnica

Cada necessidade do produto foi comparada com uma tecnologia que já está no mercado. Nenhuma exige pesquisa ou invenção.

Necessidade (do Documento de Visão)	Como se resolve	Maturidade
Conta, saldo e Pix (F03, F04, F05)	API do parceiro BaaS. O Rufus não constrói core bancário nem se conecta direto ao Pix	Modelo comum no mercado brasileiro
Pagar boleto pela câmera (F06)	Leitura do código de barras no próprio celular e pagamento pela API do parceiro	Madura
Leitura em voz alta (princípio 1)	Serviço de texto para fala. A tabela de preços da AWS em São Paulo lista o Amazon Polly a US$ 4 por milhão de caracteres. Frases fixas são geradas uma vez e guardadas no S3	Madura
Entrada por biometria (F02)	Biometria nativa do Android e do iOS. O dado biométrico fica no celular e não vai para o servidor	Madura
Abertura de conta com documento e selfie (F01)	Serviço de validação de identidade do parceiro ou de um fornecedor especializado	Madura
Saldo e movimentação sem erro	Banco relacional com transação ACID. PostgreSQL é a escolha preliminar. A decisão final, comparada com a alternativa, sai no ADR do Bloco 3 e no Bloco 5	Madura
99,9% de disponibilidade	Serviços gerenciados em 2 zonas de disponibilidade, banco Multi-AZ e balanceador de carga	Madura
Conta de menor e contato de confiança (F07, F08, F10)	Regra de negócio própria do Rufus: papéis e permissões sobre a mesma conta	Desenvolvimento próprio, sem risco técnico alto

Desenho preliminar de infraestrutura, só para calcular o custo: app mobile, uma API e um worker em containers no AWS Fargate, PostgreSQL no Amazon RDS, Application Load Balancer com WAF, tudo na região sa-east-1 (São Paulo). A região foi escolhida pela latência para o usuário brasileiro e por manter os dados no país. O Bloco 3 confirma ou muda cada peça com ADR, e o custo é recalculado se mudar.

4.2 Viabilidade operacional

Ponto	Como o Rufus opera
Modelo regulatório	O Rufus começa como empresa de tecnologia, sem autorização própria do Banco Central. A conta e o Pix ficam com um parceiro BaaS (Banking as a Service) que já é autorizado. O Rufus é a interface e a experiência
Regras que o produto precisa seguir	LGPD (Lei 13.709/2018), com cuidado especial com dados de adolescentes (art. 14) e dado biométrico, que é dado sensível. Regras do Pix e de segurança que o Banco Central impõe ao parceiro e que o parceiro repassa por contrato
Conta de menor	Adolescente de 16 e 17 anos abre conta assistido pelo responsável. O responsável aceita os termos e pode ver e limitar a movimentação

Ponto	Como o Rufus opera
Atendimento	SAC humano por chat e telefone, sempre iniciado de dentro do app, depois que o cliente já entrou com biometria. Assim o cliente sabe que quem fala com ele é o Rufus de verdade
Prevenção a fraude	Regras automáticas no backend e analista antifraude para os casos suspeitos
Validação com usuário real	Teste de uso com pessoas do perfil das personas a cada sprint. A meta numérica entra como RNF no Bloco 2
Equipe	O tamanho e o custo da equipe, com pesquisa salarial, ficam no Bloco 7

O ponto mais frágil da operação é a dependência do parceiro BaaS. Ele vira o risco R04 no item 5.

4.3 Custo de infraestrutura mensal

Preços tirados da tabela oficial da AWS (Price List API pública, a mesma base da calculadora em calculator.aws), região South America (São Paulo), preço sob demanda, consultados em 04/11/2026. Dólar pela PTAX de venda do Banco Central de 04/11/2026: **R$ 5,4778**.

Ambiente	Para que serve	USD por mês	R$ por mês
Produção	Clientes reais, alta disponibilidade em 2 zonas	600,41	3.288,92
Homologação (staging)	Testes antes de publicar, 1 zona, banco menor	207,50	1.136,64
Desenvolvimento	Cada dev roda tudo na própria máquina com Docker Compose	0,00	0,00
Total		**807,91**	**4.425,55**

A tabela item a item (quantidade, preço unitário e total de cada serviço) está em ferramentas/custo-infra/custo-gerado.md. Ela é gerada pelo script custo_infra.py, que baixa os preços oficiais e para com erro se algum preço não for encontrado.

Onde está o dinheiro em produção

Serviço	USD por mês	Por que custa isso
Banco PostgreSQL (RDS Multi-AZ, disco e backup)	227,40	Multi-AZ mantém uma cópia em outra zona e assume em caso de falha. É o que sustenta os 99,9%
NAT Gateway (2)	137,64	Um por zona, para a API falar com o parceiro BaaS mesmo se uma zona cair
Containers (Fargate)	62,00	2 tarefas da API, uma em cada zona, e 1 worker
Leitura em voz alta (Polly)	48,00	Fala gerada na hora para saldo, valores e nomes
Restante (balanceador, WAF, logs, saída de dados, IPs, segredos, S3, ECR)	125,37	Rede, segurança e observabilidade

Premissas de uso

Premissa	Valor	De onde vem
Usuários ativos por mês no 1º ano	10.000	Meta inicial. O Bloco 2 usa o mesmo número no RNF de escalabilidade
Requisições à API por mês	6 milhões	10.000 usuários x 20 acessos x 30 requisições
Dados enviados para a internet	120 GB	6 milhões de respostas de 20 KB

Premissa	Valor	De onde vem
Caracteres falados por mês	12 milhões	Metade dos usuários usa áudio: 5.000 x 30 falas x 80 caracteres
Logs	20 GB por mês, guardados por 90 dias	Estimativa para API e worker com log estruturado
Disponibilidade	99,9%	Meta que obriga 2 zonas, banco Multi-AZ, 2 NAT e balanceador

O que este valor não inclui

- Tarifa do parceiro BaaS por conta e por transação. Depende de contrato e entra no Bloco 7.
- SMS, contas nas lojas de aplicativos e domínio.
- Salários da equipe (Bloco 7).
- Descontos de reserva (Savings Plans). Com uso estável depois do lançamento, o custo de containers e banco pode cair.

Custo mensal de infraestrutura (gerado)

Arquivo gerado por `custo_infra.py`. Não editar à mão: mude as premissas no script e rode de novo.

- Região: AWS sa-east-1 (São Paulo), preço sob demanda, sem desconto de reserva.
- Tabelas de preço AWS publicadas entre 2026-09-11 e 2026-11-04.
- Câmbio: PTAX de venda de 2026-11-04, R$ 5,4778 por dólar (Banco Central).
- Gerado em 04/11/2026.

Produção

Item	Quantidade	Preço unitário (USD)	Total (USD)
API: 2 tarefas Fargate ARM (1 por zona), 0,5 vCPU cada	730 vCPU-h	0,0557	40,66
API: memória das 2 tarefas, 1 GB cada	1.460 GB-h	0,00612	8,94
Worker (filas e notificações): 1 tarefa, 0,25 vCPU	182 vCPU-h	0,0557	10,17
Worker: memória, 0,5 GB	365 GB-h	0,00612	2,23
PostgreSQL RDS db.t4g.medium Multi-AZ	730 h	0,275	200,75
Disco do banco: 50 GB gp3 Multi-AZ	50 GB-mês	0,438	21,90
Backup além da cota grátis (retenção de 35 dias)	50 GB-mês	0,095	4,75
Application Load Balancer	730 h	0,034	24,82
ALB: capacidade media de 1 LCU	730 LCU-h	0,011	8,03
NAT Gateway: 2, um por zona	1.460 h	0,093	135,78
NAT: tráfego de saída para o parceiro BaaS	20 GB	0,093	1,86
Saída para a internet (respostas da API)	120 GB	0,25	30,00
IPv4 público: 2 do ALB e 2 dos NAT	2.920 IP-h	0,005	14,60
WAF: 1 web ACL	1 ACL	5	5,00
WAF: 5 regras	5 regras	1	5,00
WAF: requisições inspecionadas	6.000.000 req	0,0000006	3,60
Secrets Manager: 10 segredos	10 segredos	0,4	4,00
CloudWatch Logs: ingestão	20 GB	0,9	18,00
CloudWatch Logs: armazenamento (90 dias)	60 GB-mês	0,0408	2,45
CloudWatch: 10 alarmes	10 alarmes	0,135	1,35
CloudWatch: 20 métricas de negócio	20 métricas	0,3	6,00
S3: comprovantes, documentos e cache de áudio	50 GB-mês	0,0405	2,02
ECR: imagens dos containers	5 GB-mês	0,1	0,50
Polly: leitura em voz alta (12 mi caracteres)	12.000.000 caracteres	0,000004	48,00
Total			**600,41**

Em reais: **R$ 3.288,92 por mês**.

Homologação (staging)

Item	Quantidade	Preço unitário (USD)	Total (USD)
API: 1 tarefa Fargate ARM, 0,5 vCPU	365 vCPU-h	0,0557	20,33
API: memória, 1 GB	730 GB-h	0,00612	4,47
Worker: 1 tarefa, 0,25 vCPU	182 vCPU-h	0,0557	10,17
Worker: memória, 0,5 GB	365 GB-h	0,00612	2,23
PostgreSQL RDS db.t4g.small Single-AZ	730 h	0,069	50,37
Disco do banco: 20 GB gp3	20 GB-mês	0,219	4,38
Application Load Balancer	730 h	0,034	24,82
ALB: capacidade mínima	73 LCU-h	0,011	0,80
NAT Gateway: 1	730 h	0,093	67,89
NAT: tráfego	2 GB	0,093	0,19
IPv4 público: 2 do ALB e 1 do NAT	2.190 IP-h	0,005	10,95
Secrets Manager: 10 segredos	10 segredos	0,4	4,00
CloudWatch Logs: ingestão	3 GB	0,9	2,70
S3	5 GB-mês	0,0405	0,20
Polly: testes (1 mi caracteres)	1.000.000 caracteres	0,000004	4,00
Total			**207,50**

Em reais: **R$ 1.136,64 por mês**.

Resumo por ambiente

Ambiente	USD por mês	R$ por mês
Produção	600,41	3.288,92
Homologação	207,50	1.136,64
Desenvolvimento	0,00	0,00 (Docker Compose na máquina do dev)
Total	**807,91**	**4.425,55**

5. Riscos iniciais

Os dois riscos mais graves são **golpe contra o usuário vulnerável (R01)** e **baixa adesão (R06)**: os dois atacam o motivo de o Rufus existir. Seis riscos vieram do grupo e dois foram acrescentados (R07 e R08) para cobrir as categorias equipe e regulatório, que a matriz do Bloco 7 exige (mínimo de 8).

Escala

Nota	Probabilidade	Impacto
1	Baixa: pode não acontecer no 1º ano	Baixo: atrasa ou incomoda, sem dano ao cliente
2	Média: pode acontecer no 1º ano	Médio: perda de dinheiro ou prazo que dá para recuperar
3	Alta: deve acontecer no 1º ano	Alto: dano ao cliente, multa ou ameaça à existência do produto

Severidade = probabilidade x impacto (de 1 a 9). De 6 para cima, o risco tem dono e plano desde o início.

Riscos

ID	Risco	Categoria	Prob.	Impacto	Severidade	Mitigação	Sinal de alerta
R01	Fraudes e golpes contra usuários vulneráveis	Segurança	3	3	**9**	O app avisa em toda tela de dinheiro que o Rufus nunca liga pedindo senha. Atendimento só começa de dentro do app. Antes do Pix, o app fala o nome de quem recebe e o valor. Limite menor para destinatário novo e à noite. Contato de confiança avisado em movimentação fora do padrão. Botão "bloquear tudo agora". Analista antifraude para casos suspeitos	Pedidos de devolução de Pix e contestações por mês
R02	Vazamento de dados pessoais	Segurança e regulatório	2	3	**6**	Criptografia em trânsito e em repouso. Coletar só o dado necessário. Segredos no Secrets Manager, nunca no código. WAF na entrada. Acesso administrativo com dois fatores. Log sem dado pessoal. Teste de invasão antes do lançamento. Plano de resposta a incidente com comunicação à ANPD e aos titulares	Alertas de acesso anormal, achados de teste de invasão
R03	Usuários não conseguem usar o app (o oposto do objetivo)	Negócio	2	3	**6**	Teste de uso com pessoas do perfil das personas a cada sprint. Áudio e ícone em toda tela. Linguagem simples revisada. Medir onde as pessoas desistem em cada fluxo	Taxa de abandono por tela, chamados de "não consigo" no SAC
R04	Não conseguir parceria regulatória (BaaS)	Regulatório e negócio	2	3	**6**	Negociar com pelo menos 2 parceiros ao mesmo tempo. Isolar a integração com o parceiro numa camada própria, para trocar de parceiro sem reescrever o sistema (vira ADR no Bloco 3). Começar a conversa antes do desenvolvimento	Nenhum contrato assinado até o fim do 1º sprint

ID	Risco	Categoria	Prob.	Impacto	Severidade	Mitigação	Sinal de alerta
R05	Custo de infraestrutura muito maior que o esperado	Técnico e financeiro	2	2	**4**	Alerta de orçamento na AWS quando o gasto passar de 80% do previsto (R$ 3.288,92 em produção). Tag de custo por ambiente. Homologação desligada fora do horário de trabalho. Frases fixas em áudio geradas uma vez e guardadas. Reserva de capacidade depois de 3 meses de uso estável	Fatura parcial acima de 80% do orçamento antes do dia 20
R06	Baixa adesão	Negócio	3	3	**9**	Conta sem tarifa. Chegar ao público por quem ele confia: a família (o neto convida a avó), associações, igrejas e quem paga diária na construção civil. Programa de indicação. Medir o uso, não só o download	Contas abertas e usuários ativos por mês abaixo da meta de 10.000
R07	Equipe sem experiência em acessibilidade e em produto financeiro	Equipe	2	2	**4**	Guia de acessibilidade no padrão do projeto (Bloco 8). Revisão de acessibilidade na Definition of Done (Bloco 9). Pelo menos uma pessoa com experiência em fintech na equipe (Bloco 7)	Telas reprovadas no teste de uso por motivo de acessibilidade
R08	Erro no tratamento de dados de menores e de dado biométrico	Regulatório	2	3	**6**	Consentimento do responsável registrado com data e versão do termo. Biometria só no celular, sem guardar no servidor. Campos com dado pessoal marcados no dicionário de dados (Bloco 5)	Pedido de titular ou da ANPD sem resposta no prazo

Matriz de risco

	Impacto 1	Impacto 2	Impacto 3
Probabilidade 3			R01, R06
Probabilidade 2		R05, R07	R02, R03, R04, R08
Probabilidade 1			

Nenhum risco ficou com probabilidade baixa: o projeto lida com dinheiro de um público que já é alvo de golpe, então o grupo preferiu ser conservador.

Bloco 2 · Requisitos

2.1 Requisitos Funcionais

32 requisitos, numerados de RF001 a RF032, cada um ligado a uma funcionalidade do Documento de Visão (F01 a F16) e priorizado por MoSCoW.

Critério de prioridade

Prioridade	Quando usamos	Quantos
Must	Sem ele o MVP não resolve o problema do Bloco 1, não passa pelo parceiro BaaS ou descumpre a lei	22
Should	Importante para as personas, mas o MVP funciona sem ele por algumas semanas	6
Could	Melhora a experiência. Entra se sobrar capacidade	2
Won't	Fica fora desta versão, de forma consciente	2

Requisitos

ID	Requisito	F	Prioridade	Justificativa
RF001	O sistema deve permitir abrir conta com foto do documento e selfie, com cada passo explicado em áudio	F01	Must	Sem conta não há produto. O áudio é o que permite Antônio abrir sozinho
RF002	O sistema deve validar a identidade do cliente no parceiro BaaS antes de liberar a conta	F01	Must	Exigência do parceiro e das regras de prevenção à lavagem de dinheiro
RF003	O sistema deve pedir uma senha de 6 números e oferecer a biometria do celular no primeiro acesso	F02	Must	Senha numérica é mais fácil para quem lê pouco. Biometria evita digitar
RF004	O sistema deve permitir entrar com biometria ou senha e bloquear o acesso por 30 minutos após 5 senhas erradas	F02	Must	Proteção contra tentativa de adivinhar a senha
RF005	O sistema deve manter um único celular ativo por conta e exigir nova selfie para trocar de aparelho	F02	Must	Impede que o golpista instale a conta da vítima no próprio celular (risco R01)
RF006	O sistema deve mostrar o saldo e o extrato com ícone por tipo de movimentação	F03	Must	É a ação mais usada. Ícone reduz a necessidade de leitura
RF007	O sistema deve ler em voz alta o conteúdo de qualquer tela pelo botão fixo "Ouvir"	F03	Must	Princípio 1 do Documento de Visão. Sem isso Antônio e Dona Marlene ficam de fora
RF008	O sistema deve permitir enviar Pix por chave, por contato salvo ou por QR Code	F04	Must	Pix é o meio de pagamento do dia a dia das três personas
RF009	O sistema deve mostrar e falar o nome do recebedor, o banco e o valor antes da confirmação do Pix	F04	Must	Última barreira contra golpe e contra erro de digitação (R01)
RF010	O sistema deve permitir receber Pix por chave e por QR Code com valor	F05	Must	Antônio recebe a diária por Pix. Sem isso ele continua dependendo do parente
RF011	O sistema deve permitir cadastrar e excluir chaves Pix de CPF, celular e aleatória	F05	Must	Pré-requisito para receber Pix por chave

ID	Requisito	F	Prioridade	Justificativa
RF012	O sistema deve gerar comprovante de Pix que pode ser ouvido e compartilhado pelo WhatsApp	F04	Should	O comprovante é pedido pelo patrão e pela família. O Pix funciona sem ele nas primeiras semanas
RF013	O sistema deve permitir pagar boleto lendo o código pela câmera ou digitando	F06	Must	Motivação principal da Dona Marlene
RF014	O sistema deve permitir abrir conta para adolescente de 16 ou 17 anos com aceite do responsável legal	F07	Must	Persona Camila. O aceite do responsável é exigido por lei
RF015	O sistema deve permitir que o responsável defina limite diário e mensal de saída da conta do menor	F08	Must	Garante a "autonomia com limite" que a Camila e os pais querem
RF016	O sistema deve permitir que o menor peça aprovação para uma saída acima do limite e que o responsável aprove ou recuse no app	F08	Should	Evita o "tudo bloqueado" dos bancos atuais. O limite fixo já protege no início
RF017	O sistema deve permitir criar meta de economia com nome, valor, data e imagem, guardar e resgatar dinheiro da meta	F09	Should	Persona Camila (notebook). Não é necessário para movimentar a conta
RF018	O sistema deve permitir cadastrar um contato de confiança, que recebe aviso de movimentação fora do padrão	F10	Should	Rede de apoio da Dona Marlene sem tirar a autonomia dela
RF019	O sistema deve aplicar limite menor para destinatário novo nas primeiras 24 horas e para Pix entre 20h e 6h	F11	Must	Os golpes acontecem com destinatário novo e com urgência (R01)
RF020	O sistema deve oferecer o botão "bloquear tudo agora", que suspende na hora todas as saídas de dinheiro	F11	Must	Resposta imediata quando o cliente percebe o golpe (R01)
RF021	O sistema deve mostrar o aviso "o Rufus nunca liga para você" nas telas de dinheiro e no início do atendimento	F11	Must	Ataca direto o golpe da falsa central, o que mais cresceu em 2025
RF022	O sistema deve lembrar o cliente de contas a vencer que ele cadastrou	F12	Could	Ajuda a Dona Marlene, mas ela já paga as contas sem o lembrete
RF023	O sistema deve oferecer dicas de educação financeira em áudio de até 60 segundos	F13	Could	Diferencial de educação. Não afeta a movimentação
RF024	O sistema deve permitir abrir chamado de atendimento por chat de dentro do app, já identificado	F14	Must	É o único canal humano. Começar dentro do app prova que é o Rufus de verdade
RF025	O sistema deve permitir que o atendente veja o histórico do cliente e responda chamados no painel do SAC	F16	Must	Sem o painel o chamado do RF024 não tem quem responda
RF026	O sistema deve dar uma nota de risco a cada Pix enviado e reter para análise os que passarem do limite de risco	F15	Must	Prevenção de fraude exigida pelo parceiro e pelo risco R01
RF027	O sistema deve permitir que o analista antifraude libere, recuse ou bloqueie a conta a partir do painel	F15	Must	Decisão humana para o Pix retido no RF026
RF028	O sistema deve enviar notificação push a cada entrada e saída de dinheiro	F03	Should	O cliente percebe na hora uma saída que não fez. O extrato já mostra o mesmo
RF029	O sistema deve permitir encerrar a conta e baixar os próprios dados pessoais	F14	Must	Direitos do titular da LGPD (art. 18)
RF030	O sistema deve permitir cadastrar funcionários e atribuir papéis (atendente, analista antifraude, administrador)	F16	Should	Controle de acesso dos painéis. No início os papéis podem ser cadastrados por script

ID	Requisito	F	Prioridade	Justificativa
RF031	Agendar Pix para data futura	F04	Won't	Pouco valor para as personas e aumenta a superfície de golpe. Fica para a próxima versão
RF032	Entrar no app por reconhecimento de voz	F02	Won't	A biometria nativa do celular já resolve, sem custo e com mais precisão

Rastreabilidade

Cada funcionalidade do Bloco 1 tem pelo menos um requisito:

F	Requisitos
F01 Abertura de conta	RF001, RF002
F02 Entrada no app	RF003, RF004, RF005, RF032
F03 Saldo e extrato	RF006, RF007, RF028
F04 Enviar Pix	RF008, RF009, RF012, RF031
F05 Receber Pix	RF010, RF011
F06 Pagar contas	RF013
F07 Conta de menor	RF014
F08 Limites e aprovação	RF015, RF016
F09 Metas	RF017
F10 Contato de confiança	RF018
F11 Proteção contra golpe	RF019, RF020, RF021
F12 Lembrete de contas	RF022
F13 Educação financeira	RF023
F14 Atendimento e direitos	RF024, RF029
F15 Antifraude	RF026, RF027
F16 Painel do SAC	RF025, RF030

2.2 Requisitos Não Funcionais

14 requisitos, todos com um número que pode ser medido e com a forma de medir. Cada um diz de onde veio o número e qual bloco seguinte ele obriga.

ID	Categoria	Requisito com métrica	Como medir	Prioridade	Por que esse número	Obriga
RNF01	Desempenho	Rotas de leitura da API (saldo, extrato, metas) respondem em menos de **300 ms no p95**, sem contar o tempo do parceiro BaaS	Métrica de latência por rota no CloudWatch e teste de carga	Must	Acima de 1 s o usuário perde a sensação de resposta imediata. 300 ms deixa folga para a rede móvel	Bloco 6: alarme de p95
RNF02	Desempenho	Pix enviado fica confirmado ou recusado na tela em até **10 s no p95**, do toque em "confirmar" à resposta	Métrica de tempo entre pedido e resposta do parceiro	Must	Dona Marlene tem medo de errar. Ficar sem resposta gera clique repetido e Pix duplicado	Bloco 3: chamada ao parceiro com timeout e idempotência
RNF03	Disponibilidade	**99,9% ao mês** (até 43 minutos fora do ar por mês)	Verificação externa a cada 1 minuto no endpoint de saúde	Must	Conta é serviço essencial: quem recebe a diária por Pix precisa do app disponível	Bloco 6: 2 zonas, RDS Multi-AZ, balanceador. Já custeado no Bloco 1
RNF04	Escalabilidade	Suportar **10.000 usuários ativos por mês** e picos de **100 requisições por segundo** mantendo o RNF01	Teste de carga com k6 antes de cada versão grande	Must	10.000 é a meta do 1º ano (Bloco 1). 100 req/s é cerca de 40 vezes a média de 6 milhões de requisições por mês	Bloco 6: auto scaling de 2 a 6 tarefas
RNF05	Segurança	Senha guardada com **Argon2id**. Token de acesso vale **15 minutos**, token de renovação **30 dias**, trocado a cada uso. Toda conexão em **TLS 1.2 ou superior**	Revisão de código e teste automatizado de configuração	Must	Padrão recomendado pela OWASP para senha e sessão em app financeiro	Bloco 6: seção de segurança
RNF06	Segurança	**Nenhuma vulnerabilidade crítica ou alta** conhecida em dependência ou imagem no momento do deploy	Varredura no pipeline (npm audit e Trivy)	Must	Vulnerabilidade conhecida é a porta mais fácil para vazamento (R02)	Bloco 6: o pipeline bloqueia o deploy
RNF07	LGPD	**100% dos campos com dado pessoal marcados** no dicionário de dados. CPF e data de nascimento **criptografados** no banco. Pedido do titular respondido em até **15 dias**	Revisão do dicionário de dados e prazo dos pedidos registrados	Must	A LGPD (art. 19) dá 15 dias para a resposta completa ao titular	Bloco 5: dicionário com coluna LGPD

ID	Categoria	Requisito com métrica	Como medir	Prioridade	Por que esse número	Obriga
RNF08	Usabilidade	Ver saldo, enviar Pix e pagar boleto em **no máximo 3 toques** depois do login. Em teste com 5 pessoas do perfil das personas, **pelo menos 4 pagam um boleto sem ajuda em até 3 minutos**	Teste de uso a cada sprint, com cronômetro	Must	É a promessa do produto. 5 pessoas por rodada é o número clássico de teste de usabilidade (Nielsen)	Bloco 9: o teste entra na DoD das telas
RNF09	Acessibilidade	Seguir a **WCAG 2.2 nível AA**: contraste de pelo menos **4,5:1**, área de toque de pelo menos **48 dp**, texto base de **18 sp**, funcionar com TalkBack e VoiceOver. **100% das telas** com o botão "Ouvir"	Checklist automático e teste manual com leitor de tela	Must	Antônio e Dona Marlene leem com dificuldade. 48 dp é o mínimo do guia do Android	Bloco 9: DoD
RNF10	Compatibilidade	Funcionar em **Android 10 ou superior** e **iOS 16 ou superior**, em celular com **3 GB de RAM**	Teste em aparelho real de entrada antes da publicação	Must	Antônio usa um Android de entrada	Bloco 3: escolha do framework mobile
RNF11	Integridade	**Zero Pix duplicado** por clique repetido ou falha de rede. Diferença entre o nosso razão contábil e o parceiro **detectada em até 24 horas**	Teste automatizado de idempotência e conciliação diária	Must	Erro de dinheiro destrói a confiança de quem já tem medo de errar	Bloco 3: chave de idempotência. Bloco 5: razão com partidas dobradas
RNF12	Recuperação	Perda máxima de dados (RPO) de **5 minutos** e volta ao ar (RTO) em até **1 hora** após falha grave	Teste de restauração do backup a cada 3 meses	Must	O RDS restaura para um ponto de até 5 minutos atrás. 1 hora cabe nos 43 minutos do RNF03 quando a falha é rara	Bloco 5: estratégia de backup
RNF13	Observabilidade	**100% das requisições** com identificador de correlação no log. Alerta em até **5 minutos** quando a taxa de erro passar de **2%**	Configuração dos alarmes no CloudWatch	Should	Sem isso uma falha só é percebida pela reclamação do cliente	Bloco 6: observabilidade
RNF14	Auditoria	Toda ação de funcionário (consulta e alteração) registrada e guardada por **5 anos**	Consulta à tabela de auditoria	Must	A Lei 9.613/1998 (prevenção à lavagem de dinheiro) exige guardar registros por 5 anos	Bloco 5: tabela de auditoria

Por que esses são Must

Treze dos 14 são Must porque cada um protege diretamente o dinheiro do cliente (RNF02, RNF05, RNF06, RNF11, RNF12), a promessa do produto (RNF08, RNF09, RNF10), a lei (RNF07, RNF14) ou a meta de operação do Bloco 1 (RNF01, RNF03, RNF04). O RNF13 é Should porque a observabilidade completa pode amadurecer depois do lançamento; o mínimo de alarmes já entra no Must do RNF03.

2.3 Histórias de Usuário

24 histórias no formato "Como [persona], quero [ação], para [objetivo]", cada uma com critérios de aceite em Given/When/Then (Dado/Quando/Então) e estimativa em story points.

Escala de story points

Sequência de Fibonacci (1, 2, 3, 5, 8, 13), estimada pela equipe por comparação. A história de referência é a **US13 (cadastrar contato de confiança) = 3 pontos**: um formulário, uma regra e uma notificação. Uma história de 13 pontos é grande demais para um sprint e precisa ser quebrada antes de entrar.

Resumo

ID	Persona	História	RF	MoSCoW	SP
US01	Antônio	Abrir a conta ouvindo cada passo	RF001, RF002	Must	8
US02	Antônio	Entrar com a digital	RF003, RF004	Must	5
US03	Dona Marlene	Trocar de celular com selfie	RF005	Must	5
US04	Antônio	Ouvir o saldo e o extrato	RF006, RF007	Must	5
US05	Antônio	Receber a diária por QR Code	RF010, RF011	Must	5
US06	Dona Marlene	Enviar Pix ouvindo para quem vai	RF008, RF009	Must	8
US07	Antônio	Não mandar Pix em dobro	RF008, RNF11	Must	3
US08	Dona Marlene	Pagar boleto pela câmera	RF013	Must	8
US09	Camila	Abrir conta com aceite do pai	RF014	Must	8
US10	Responsável da Camila	Definir limite da conta da filha	RF015	Must	3
US11	Antônio	Ter limite menor com destinatário novo e à noite	RF019	Must	3
US12	Dona Marlene	Bloquear tudo na hora	RF020, RF021	Must	3
US14	Antônio	Falar com uma pessoa pelo chat do app	RF024	Must	5
US15	Atendente do SAC	Responder chamado vendo o histórico	RF025	Must	5
US16	Analista antifraude	Analisar Pix retido	RF026, RF027	Must	8
US17	Antônio	Encerrar a conta e baixar meus dados	RF029	Must	5
US13	Dona Marlene	Cadastrar o neto como contato de confiança	RF018	Should	3
US18	Camila	Pedir aprovação acima do limite	RF016	Should	5
US19	Camila	Criar a meta do notebook	RF017	Should	5
US20	Camila	Receber aviso de cada movimentação	RF028	Should	3
US21	Dona Marlene	Ouvir e compartilhar o comprovante	RF012	Should	3
US22	Administrador	Cadastrar funcionário com papel	RF030	Should	3
US23	Dona Marlene	Lembrete de conta a vencer	RF022	Could	3
US24	Camila	Ouvir dicas de dinheiro	RF023	Could	2
		Total			**114**

Must: 87 pontos em 16 histórias. Should: 22 pontos em 6 histórias. Could: 5 pontos em 2 histórias. O Bloco 7 soma a isso as tarefas técnicas (infraestrutura, pipeline, integração com o parceiro) e calcula os sprints.

Histórias com critérios de aceite

US01 · Abrir a conta ouvindo cada passo (8 SP, Must)

Como **Antônio**, quero abrir minha conta ouvindo o que fazer em cada passo, para não depender de ninguém para ler as instruções.

- **Dado** que instalei o app e toquei em "Abrir conta", **quando** cada tela aparece, **então** a instrução é falada automaticamente e pode ser repetida pelo botão "Ouvir".
- **Dado** que enviei foto do documento e selfie, **quando** o parceiro aprova a identidade, **então** a conta fica ativa e o app avisa por voz e por push.
- **Dado** que a foto ficou escura ou cortada, **quando** o envio é recusado, **então** o app fala o motivo em uma frase ("a foto ficou escura, tente perto da janela") e permite tentar de novo.

US02 · Entrar com a digital (5 SP, Must)

Como **Antônio**, quero entrar no app com a minha digital, para não precisar lembrar nem digitar senha.

- **Dado** que criei a senha de 6 números, **quando** aceito usar a biometria, **então** os próximos acessos pedem só a digital.
- **Dado** que errei a senha 5 vezes, **quando** tento a 6ª, **então** o acesso fica bloqueado por 30 minutos e o app explica por voz.
- **Dado** que meu celular não tem biometria, **quando** entro, **então** o app pede a senha de 6 números com teclado grande.

US03 · Trocar de celular com selfie (5 SP, Must)

Como **Dona Marlene**, quero que só o meu celular acesse a minha conta, para que ninguém instale minha conta em outro aparelho.

- **Dado** que minha conta já está ativa num celular, **quando** alguém tenta entrar em outro aparelho, **então** o app exige uma selfie nova e só libera se ela bater com a do cadastro.
- **Dado** que a troca de aparelho foi aprovada, **quando** a nova sessão começa, **então** o aparelho antigo é desconectado e eu recebo aviso no contato cadastrado.

US04 · Ouvir o saldo e o extrato (5 SP, Must)

Como **Antônio**, quero ouvir quanto dinheiro eu tenho e o que entrou e saiu, para saber das minhas contas sem ler.

- **Dado** que entrei no app, **quando** a tela inicial abre, **então** o saldo aparece em número grande com o botão "Ouvir" ao lado.
- **Dado** que toquei em "Ouvir" no extrato, **quando** o áudio toca, **então** cada movimentação é falada como "Recebeu 120 reais de José, ontem".
- **Dado** que estou na tela inicial, **quando** quero ver o extrato, **então** chego nele com 1 toque.

US05 · Receber a diária por QR Code (5 SP, Must)

Como **Antônio**, quero mostrar um QR Code para o mestre de obras me pagar, para receber a diária na minha conta.

- **Dado** que toquei em "Receber", **quando** digito o valor (ou deixo em branco), **então** o app mostra um QR Code Pix em tela cheia.

- **Dado** que o pagamento caiu, **quando** o parceiro confirma, **então** o celular vibra, fala "Recebeu 150 reais de Carlos" e o saldo é atualizado.

US06 · Enviar Pix ouvindo para quem vai (8 SP, Must)

Como **Dona Marlene**, quero ouvir o nome de quem vai receber e o valor antes de confirmar, para ter certeza de que não estou errando.

- **Dado** que informei a chave e o valor, **quando** chego na tela de confirmação, **então** o app mostra e fala o nome do recebedor, o banco e o valor.
- **Dado** que confirmei com a biometria, **quando** o parceiro aceita o Pix, **então** o app mostra "Pix enviado" com ícone verde em até 10 segundos (RNF02).
- **Dado** que o saldo não é suficiente, **quando** tento confirmar, **então** o app avisa antes de pedir a biometria e não envia nada.

US07 · Não mandar Pix em dobro (3 SP, Must)

Como **Antônio**, quero que o Pix não saia duas vezes se eu apertar o botão de novo, para não perder dinheiro.

- **Dado** que toquei em "confirmar" e a internet caiu, **quando** o app reenvia o pedido, **então** o servidor reconhece a mesma chave de idempotência e devolve o resultado do primeiro pedido.
- **Dado** que toquei duas vezes seguidas, **quando** os dois pedidos chegam, **então** só um Pix é criado.

US08 · Pagar boleto pela câmera (8 SP, Must)

Como **Dona Marlene**, quero apontar a câmera para a conta de luz e pagar, para não precisar digitar aquele número enorme.

- **Dado** que abri "Pagar conta", **quando** aponto a câmera para o código de barras, **então** o app lê o código e mostra e fala a empresa, o valor e o vencimento.
- **Dado** que o código não foi lido em 15 segundos, **quando** o tempo acaba, **então** o app oferece digitar o código com teclado grande.
- **Dado** que o boleto está vencido, **quando** o valor é calculado, **então** o app mostra os juros separados e fala o total.

US09 · Abrir conta com aceite do pai (8 SP, Must)

Como **Camila**, quero abrir minha conta com meu pai aceitando pelo celular dele, para não precisar ir a lugar nenhum.

- **Dado** que informei que tenho 17 anos, **quando** termino meu cadastro, **então** o app pede o CPF e o celular do responsável e envia um convite para ele.
- **Dado** que meu pai abriu o convite, **quando** ele confirma a identidade e aceita os termos, **então** minha conta fica ativa vinculada a ele.
- **Dado** que o responsável não aceitou em 7 dias, **quando** o prazo vence, **então** o pedido é cancelado e os dados enviados são apagados.

US10 · Definir limite da conta da filha (3 SP, Must)

Como **responsável da Camila**, quero definir quanto ela pode gastar por dia e por mês, para ela ter autonomia sem risco.

- **Dado** que sou o responsável vinculado, **quando** defino o limite diário e o mensal, **então** os novos limites valem na hora.
- **Dado** que a Camila tenta um Pix acima do limite, **quando** ela confirma, **então** o Pix não é enviado e ela vê a opção de pedir aprovação (US18).

US11 · Limite menor com destinatário novo e à noite (3 SP, Must)

Como **Antônio**, quero que o app limite Pix para alguém novo e à noite, para que um golpista não leve tudo de uma vez.

- **Dado** que o destinatário nunca recebeu Pix meu, **quando** envio nas primeiras 24 horas, **então** o limite é de R$ 300 por Pix.
- **Dado** que são entre 20h e 6h, **quando** envio um Pix, **então** o limite é de R$ 1.000 por período, como na regra do Pix noturno.
- **Dado** que bati o limite, **quando** a mensagem aparece, **então** o app explica o motivo em uma frase e diz quando libera.

US12 · Bloquear tudo na hora (3 SP, Must)

Como **Dona Marlene**, quero um botão para travar a conta na hora, para me proteger se eu achar que caí num golpe.

- **Dado** que toquei em "bloquear tudo agora" e confirmei, **quando** o bloqueio é aplicado, **então** nenhuma saída de dinheiro é aceita e o contato de confiança é avisado.
- **Dado** que a conta está bloqueada, **quando** eu quiser desbloquear, **então** preciso de selfie e de 1 hora de espera.
- **Dado** que estou em qualquer tela de dinheiro, **quando** ela abre, **então** aparece o aviso "o Rufus nunca liga para você".

US13 · Cadastrar o neto como contato de confiança (3 SP, Should)

Como **Dona Marlene**, quero que meu neto seja avisado se sair dinheiro estranho da minha conta, para ter ajuda sem dar a ele acesso à conta.

- **Dado** que informei o nome e o celular do meu neto, **quando** ele aceita o convite, **então** ele vira meu contato de confiança.
- **Dado** que sai um Pix acima de 3 vezes a minha média, **quando** o Pix é confirmado, **então** meu neto recebe aviso com o valor, sem ver meu saldo.

US14 · Falar com uma pessoa pelo chat do app (5 SP, Must)

Como **Antônio**, quero falar com uma pessoa de dentro do app, para ter certeza de que é o banco mesmo.

- **Dado** que toquei em "Falar com uma pessoa", **quando** o chat abre, **então** o atendente já sabe quem eu sou e eu não preciso informar senha nem código.
- **Dado** que prefiro falar, **quando** toco no microfone, **então** posso mandar mensagem de áudio no chat.

US15 · Responder chamado vendo o histórico (5 SP, Must)

Como **atendente do SAC**, quero ver o histórico do cliente ao abrir o chamado, para resolver sem fazer o cliente repetir tudo.

- **Dado** que abri um chamado, **quando** o painel carrega, **então** vejo os chamados anteriores e as últimas 10 movimentações do cliente.
- **Dado** que respondi o chamado, **quando** o cliente lê, **então** a resposta também pode ser ouvida no app.
- **Dado** que consultei os dados do cliente, **quando** a consulta acontece, **então** ela fica registrada na auditoria (RNF14).

US16 · Analisar Pix retido (8 SP, Must)

Como **analista antifraude**, quero ver os Pix retidos com o motivo da nota de risco, para decidir rápido se libero ou bloqueio.

- **Dado** que um Pix passou da nota de risco, **quando** ele é retido, **então** aparece na fila do painel com o motivo (destinatário novo, valor fora do padrão, horário).
- **Dado** que liberei o Pix, **quando** a decisão é salva, **então** o Pix segue para o parceiro e o cliente é avisado.
- **Dado** que recusei e bloqueei, **quando** a decisão é salva, **então** o valor volta ao saldo, a conta fica bloqueada e o cliente recebe aviso para falar com o SAC pelo app.

US17 · Encerrar a conta e baixar meus dados (5 SP, Must)

Como **Antônio**, quero encerrar minha conta e receber meus dados, para exercer meus direitos.

- **Dado** que pedi para baixar meus dados, **quando** o arquivo fica pronto, **então** recebo no app um arquivo com meus dados pessoais e movimentações.
- **Dado** que pedi o encerramento com saldo zero, **quando** confirmo, **então** a conta é encerrada e os dados pessoais são anonimizados, mantidos só os registros que a lei obriga guardar.

US18 · Pedir aprovação acima do limite (5 SP, Should)

Como **Camila**, quero pedir ao meu pai para liberar um gasto acima do limite, para não ficar travada quando preciso.

- **Dado** que meu Pix passou do limite, **quando** toco em "pedir aprovação", **então** meu responsável recebe push com valor e destinatário.
- **Dado** que ele aprovou em até 24 horas, **quando** a aprovação chega, **então** o Pix é enviado e eu sou avisada.
- **Dado** que ele recusou ou não respondeu em 24 horas, **quando** o prazo acaba, **então** o pedido é cancelado.

US19 · Criar a meta do notebook (5 SP, Should)

Como **Camila**, quero criar uma meta com a foto do notebook e ver quanto falta, para ter motivação para guardar.

- **Dado** que criei a meta com nome, valor e data, **quando** guardo dinheiro nela, **então** o valor sai do saldo e a barra de progresso avança.
- **Dado** que resgatei da meta, **quando** confirmo, **então** o valor volta para o saldo.

US20 · Receber aviso de cada movimentação (3 SP, Should)

Como **Camila**, quero receber notificação de cada entrada e saída, para saber na hora se algo estranho aconteceu.

- **Dado** que entrou ou saiu dinheiro, **quando** o lançamento é confirmado, **então** recebo push em até 30 segundos com valor e tipo.

US21 · Ouvir e compartilhar o comprovante (3 SP, Should)

Como **Dona Marlene**, quero mandar o comprovante pelo WhatsApp, para provar que paguei.

- **Dado** que o Pix ou boleto foi concluído, **quando** toco em "comprovante", **então** vejo o comprovante, posso ouvi-lo e compartilhar como imagem.

US22 · Cadastrar funcionário com papel (3 SP, Should)

Como **administrador**, quero cadastrar funcionários com um papel, para que cada um veja só o que precisa.

- **Dado** que cadastrei um atendente, **quando** ele entra no painel, **então** vê os chamados mas não a fila antifraude.
- **Dado** que o funcionário entra pela primeira vez, **quando** faz login, **então** é obrigado a configurar o segundo fator.

US23 · Lembrete de conta a vencer (3 SP, Could)

Como **Dona Marlene**, quero ser lembrada da conta de água, para não pagar multa.

- **Dado** que cadastrei a conta com dia de vencimento, **quando** faltam 3 dias, **então** recebo push e o lembrete aparece na tela inicial.

US24 · Ouvir dicas de dinheiro (2 SP, Could)

Como **Camila**, quero ouvir dicas curtas sobre dinheiro, para aprender a guardar melhor.

- **Dado** que abri "Dicas", **quando** escolho uma, **então** ouço um áudio de até 60 segundos e posso ler o texto.

Bloco 3 · Arquitetura de Software

3.1 Architecture Decision Records (ADR)

Um ADR por decisão relevante. Cada um tem contexto, decisão, alternativas descartadas com o motivo e consequências. Os motivos saem dos requisitos do Bloco 2 (RF e RNF) e das premissas do Bloco 1, nunca de "é popular" ou "conhecemos".

ADR	Decisão	Status
ADR-001	Monolito modular	Aceito
ADR-002	Parceiro BaaS atrás de uma porta com adaptador	Aceito
ADR-003	REST com JSON e contrato OpenAPI 3.0	Aceito
ADR-004	Backend em TypeScript com NestJS sobre Node.js 22	Aceito
ADR-005	App em React Native com Expo	Aceito
ADR-006	PostgreSQL 17 no Amazon RDS Multi-AZ	Aceito
ADR-007	Razão contábil com partidas dobradas	Aceito
ADR-008	Eventos por outbox transacional no próprio PostgreSQL	Aceito
ADR-009	Containers no ECS Fargate	Aceito
ADR-010	Autenticação própria com JWT curto e celular vinculado	Aceito
ADR-011	Voz gerada no servidor, com cache	Aceito
ADR-012	Painéis internos servidos pela própria API	Aceito
ADR-013	AWS na região de São Paulo	Aceito

ADR-001 · Monolito modular, e não microsserviços

Contexto. O MVP atende 10.000 usuários ativos por mês com picos de 100 requisições por segundo (RNF04). A equipe tem 2 desenvolvedores de backend (Bloco 7). Os módulos (contas, Pix, família, antifraude, atendimento) trocam dados o tempo todo e várias operações precisam mexer em mais de um deles na mesma transação: um Pix debita a carteira, passa pelo antifraude e grava o evento de notificação (RNF11, zero Pix duplicado).

Decisão. Uma aplicação única (API) e um worker, os dois do mesmo código, divididos em módulos com fronteiras explícitas: cada módulo só expõe um serviço público e só ele escreve nas próprias tabelas. Um único banco PostgreSQL.

Alternativas descartadas.

Alternativa	Por que não
Microsserviços, um por módulo	Cada serviço teria o próprio banco, e o Pix viraria uma transação distribuída entre 3 serviços (saga com compensação em cada um). Para 100 req/s não há ganho de escala que pague isso. Exigiria 6 bancos ou mais, o que muda o custo do Bloco 1. 2 devs de backend não sustentam a operação de vários serviços
Monolito sem módulos	Resolve hoje, mas mistura as regras de antifraude com as de conta e impede extrair um módulo depois

Consequências. Transações locais garantem o RNF11 com uma transação do banco. Deploy único e simples. Se um módulo precisar escalar sozinho (o antifraude, por exemplo), ele já tem fronteira e pode virar serviço. Risco: alguém acessar a tabela de outro módulo. Mitigação: regra de lint de dependência entre módulos no pipeline (Bloco 6).

ADR-002 · Parceiro BaaS atrás de uma porta com adaptador

Contexto. Conta, Pix e boleto dependem de um parceiro autorizado pelo Banco Central (Bloco 1). O parceiro ainda não está contratado e existe o risco de não conseguir ou de precisar trocar (risco R04).

Decisão. Padrão Portas e Adaptadores (arquitetura hexagonal) para tudo que é externo. O domínio conversa com interfaces nossas (`PortaBancaria` , `PortaVoz` , `PortaNotificacao` , `PortaIdentidade`). Cada fornecedor ganha um adaptador que traduz o modelo dele para o nosso (camada anticorrupção). Em desenvolvimento e teste roda um adaptador falso, sem rede.

Alternativas descartadas.

Alternativa	Por que não
Usar o SDK do parceiro direto nos serviços	Prende o domínio ao parceiro. Trocar de parceiro (R04) obrigaria a reescrever Pix, boleto e conta
Contratar um agregador de vários bancos	Coloca mais um intermediário cobrando por transação. Não elimina a dependência, só muda de fornecedor

Consequências. Trocar de parceiro vira escrever um adaptador novo. O dev pode rodar tudo no localhost sem contrato assinado. Custo: uma camada a mais de tradução para manter.

ADR-003 · REST com JSON e contrato OpenAPI 3.0

Contexto. Os clientes da API são o app mobile e os painéis web. Os parceiros BaaS do mercado expõem REST e avisam eventos por webhook HTTP. O enunciado pede contrato OpenAPI 3.0 (Bloco 8).

Decisão. API REST com JSON, versionada no caminho (`/v1`), descrita em OpenAPI 3.0. Operações que movem dinheiro exigem o cabeçalho `Idempotency-Key` .

Alternativas descartadas.

Alternativa	Por que não
gRPC	O ganho de desempenho do protocolo binário não é necessário para 100 req/s com p95 de 300 ms (RNF01). Navegador não fala gRPC sem proxy, e os painéis web precisariam de gRPC-Web. Webhooks do parceiro são HTTP de qualquer forma
GraphQL	As telas são simples e fixas, por isso não há o problema de buscar dados demais. Dificulta cache e limite por rota no WAF. Idempotência por operação é mais natural em REST

Consequências. O cliente do app é gerado a partir do OpenAPI, então o contrato não diverge do código. Ferramentas de teste e de documentação (Swagger UI) prontas.

ADR-004 · Backend em TypeScript com NestJS sobre Node.js 22

Contexto. A carga é de entrada e saída (banco, parceiro, voz), não de cálculo pesado. Precisamos de tipagem forte para dinheiro e de módulos com fronteira clara (ADR-001). O app mobile é em TypeScript (ADR-005). Cada tarefa no Fargate tem 1 GB de memória (custo do Bloco 1).

Decisão. Node.js 22 LTS, TypeScript em modo estrito e framework NestJS. Valores em dinheiro sempre em centavos inteiros (`bigint` no banco).

Alternativas descartadas.

Alternativa	Por que não
Java 21 com Spring Boot	Muito usado em bancos e igualmente adequado. Descartado porque uma aplicação Spring com JVM costuma precisar de mais memória por tarefa que os 1 GB custeados, e porque exigiria uma segunda linguagem na equipe: os tipos do contrato não seriam compartilhados com o app
Go	Ótimo desempenho e baixo consumo de memória, mas sem framework modular equivalente ao NestJS: módulos, injeção de dependência e validação teriam de ser montados à mão. Mesma questão da segunda linguagem

Consequências. Uma linguagem só no app, na API e no worker. O NestJS dá módulos, injeção de dependência (que permite trocar adaptadores do ADR-002) e validação de entrada. Cuidado: número em JavaScript perde precisão acima de 2^53, por isso dinheiro trafega como inteiro em centavos e o banco usa `bigint`.

ADR-005 · App em React Native com Expo

Contexto. Android e iOS (RNF10), celular de entrada com 3 GB de RAM, leitor de tela TalkBack e VoiceOver obrigatório (RNF09), câmera para boleto (RF013), biometria (RF003).

Decisão. React Native com Expo, em TypeScript.

Alternativas descartadas.

Alternativa	Por que não
Flutter	Desenha a própria interface em vez de usar os componentes nativos, então a acessibilidade depende de anotar a árvore de semântica em cada widget. No React Native os componentes já são os nativos e o TalkBack e o VoiceOver os leem sem trabalho extra, que é o RNF mais importante do produto. Também usaria Dart, uma segunda linguagem
Dois apps nativos (Kotlin e Swift)	Melhor acesso a cada plataforma, mas dobra o trabalho mobile e exige dois perfis diferentes na equipe

Consequências. Um código para os dois sistemas. Biometria, câmera e armazenamento seguro (Keystore e Keychain) por bibliotecas do Expo. Atualização de correção sem esperar a loja (EAS Update), útil para corrigir texto de acessibilidade.

ADR-006 · PostgreSQL 17 no Amazon RDS Multi-AZ

Contexto. Dinheiro exige transação ACID entre várias linhas (RNF11), chaves estrangeiras e restrições. Disponibilidade de 99,9% (RNF03) e RPO de 5 minutos (RNF12).

Decisão. PostgreSQL 17 gerenciado no Amazon RDS, com réplica síncrona em outra zona (Multi-AZ). A comparação completa com a alternativa descartada e o modelo estão no Bloco 5.

Alternativas descartadas. MongoDB (documento) e Amazon Aurora PostgreSQL. Motivos detalhados no Bloco 5, item 5.1.

Consequências. Failover automático para a réplica. Backup com restauração a qualquer ponto dos últimos 35 dias. Custo já no Bloco 1 (US$ 227,40 por mês em produção).

ADR-007 · Razão contábil com partidas dobradas

Contexto. Saldo errado é o pior erro possível para o público do Rufus. A diferença entre o nosso registro e o do parceiro precisa ser detectada em até 24 horas (RNF11).

Decisão. Toda movimentação gera lançamentos em partidas dobradas: cada transação tem pelo menos um débito e um crédito, e a soma é zero. O saldo de uma carteira é a soma dos lançamentos dela, nunca um número editado. Um gatilho no banco recusa transação desequilibrada.

Alternativas descartadas.

Alternativa	Por que não
Coluna `saldo` atualizada a cada operação	Duas operações ao mesmo tempo podem sobrescrever uma à outra, e quando o saldo diverge não há trilha para explicar o porquê
Guardar só o saldo informado pelo parceiro	Deixa o Rufus sem registro próprio para conciliar e para mostrar o extrato quando o parceiro está fora

Consequências. Extrato e auditoria saem do mesmo registro. A conciliação diária compara a soma por carteira com o extrato do parceiro. Custo: a consulta de saldo soma lançamentos; com índice por carteira e saldo de fechamento diário, fica dentro dos 300 ms (RNF01).

ADR-008 · Eventos por outbox transacional no próprio PostgreSQL

Contexto. Depois de um Pix é preciso enviar ao parceiro, notificar o cliente, avisar o contato de confiança e o responsável. Se a API gravar o Pix e cair antes de avisar, o aviso se perde. Se avisar antes de gravar, avisa algo que não aconteceu.

Decisão. Padrão Transactional Outbox: na mesma transação que grava o Pix, a API grava o evento na tabela `outbox_evento`. O worker lê os eventos pendentes com `FOR UPDATE SKIP LOCKED`, executa e marca como processado, com nova tentativa e espera crescente em caso de erro.

Alternativas descartadas.

Alternativa	Por que não
Amazon SQS	Gravar no banco e publicar na fila são duas operações que podem falhar separadas, e o problema voltaria. Seria preciso o outbox de qualquer forma
Kafka (Amazon MSK)	Feito para milhões de eventos por segundo. Para o volume do Rufus seria um cluster caro e mais uma peça para operar

Consequências. Garantia de "pelo menos uma vez": cada consumidor é idempotente. Nenhum serviço novo na infraestrutura do Bloco 1. Se o volume crescer muito, o worker pode passar a publicar do outbox para uma fila.

ADR-009 · Containers no ECS Fargate

Contexto. Duas cargas: a API, sempre ligada e com p95 de 300 ms (RNF01), e o worker, que fica lendo o outbox (ADR-008). 99,9% exige pelo menos 2 zonas (RNF03).

Decisão. Amazon ECS com Fargate: containers sem gerenciar servidor, 2 tarefas da API (uma por zona) e 1 do worker, com auto scaling de 2 a 6 tarefas da API.

Alternativas descartadas.

Alternativa	Por que não
Kubernetes (EKS)	O plano de controle custa US$ 0,10 por hora por cluster em São Paulo, US$ 73 por mês, e seriam 2 clusters (produção e homologação). Exige uma pessoa que domine Kubernetes. Os recursos extras não são usados por 2 serviços
AWS Lambda	O worker fica em execução contínua e a API mantém conexões com o PostgreSQL. Em Lambda, a partida a frio ameaça o p95 de 300 ms e cada execução abriria conexão nova com o banco, exigindo RDS Proxy
EC2 com Docker	Mais barato por hora, mas a equipe teria de cuidar de sistema operacional, atualização de segurança e substituição de máquina com defeito

Consequências. O mesmo container roda no localhost (Docker Compose) e na AWS. Custo de containers no Bloco 1: US$ 62,00 por mês em produção.

ADR-010 · Autenticação própria com JWT curto e celular vinculado

Contexto. Só um celular ativo por conta e troca de aparelho com selfie (RF005). Senha de 6 números e biometria (RF003, RF004). Sessão segura (RNF05). Funcionários precisam de papéis diferentes (RF030) e de segundo fator.

Decisão. Módulo de identidade próprio. No cadastro o app gera um par de chaves no Keystore ou Keychain do celular e envia a chave pública. O login exige senha (guardada com Argon2id) e a assinatura do aparelho. A API emite token de acesso JWT de 15 minutos e token de renovação de 30 dias, trocado a cada uso e guardado só como hash. A biometria destrava a chave no celular e nunca sai dele. Funcionários entram com senha e código TOTP e recebem papéis (RBAC). A relação entre menor e responsável é checada por atributo do vínculo (ABAC).

Alternativas descartadas.

Alternativa	Por que não
Amazon Cognito	Resolve usuário e senha, mas não tem vínculo de um único aparelho com assinatura por chave do celular nem as regras de menor e responsável. Teríamos de escrever essas regras de qualquer forma, e com duas fontes de verdade
Sessão no servidor com cookie	App mobile não usa cookie de forma natural e cada requisição consultaria a sessão no banco

Consequências. Controle total do fluxo de troca de aparelho, que é a principal barreira contra golpe (R01). Responsabilidade maior: o módulo de identidade tem a meta de cobertura de testes mais alta (Bloco 9).

ADR-011 · Voz gerada no servidor, com cache

Contexto. Toda tela precisa poder ser ouvida (RF007, RNF09). Os celulares de entrada nem sempre têm voz em português instalada e a qualidade varia de aparelho para aparelho.

Decisão. A API gera o áudio com o Amazon Polly. Frases fixas (instruções de tela) são geradas uma vez e guardadas no S3. Frases com dados (saldo, nome do recebedor) são geradas na hora e não são guardadas. Se o celular estiver sem internet, o app usa a voz do próprio aparelho.

Alternativas descartadas.

Alternativa	Por que não
Só a voz do celular	Custo zero, mas a voz pode faltar ou soar diferente em cada aparelho. Para quem depende do áudio, a voz é a interface
Gravar todas as frases com locutor	Não cobre frases com dados (valores, nomes)

Consequências. Mesma voz em todos os aparelhos. Custo no Bloco 1: US$ 48 por mês para 12 milhões de caracteres. A tabela de preços de São Paulo lista só a voz padrão do Polly; a voz neural fica como melhoria.

ADR-012 · Painéis internos servidos pela própria API

Contexto. SAC, antifraude e administração precisam de painéis web (RF025, RF027, RF030). São poucos usuários internos.

Decisão. Uma aplicação React (Vite) compilada como arquivos estáticos e servida pela API em `/admin`. O acesso ao caminho `/admin` só é aceito a partir dos IPs da empresa (regra do WAF), com senha e TOTP.

Alternativas descartadas.

Alternativa	Por que não
Hospedar no S3 com CloudFront	Mais uma distribuição para configurar e proteger, para poucos usuários internos
Ferramenta pronta de painel (low-code)	Os dados de cliente sairiam para um terceiro, o que piora o risco R02 e a LGPD

Consequências. Nenhum serviço novo na infraestrutura. O painel usa a mesma API, com rotas `/v1/admin` protegidas por papel.

ADR-013 · AWS na região de São Paulo

Contexto. Os dados são de brasileiros, incluindo menores e biometria. A latência para o usuário afeta o RNF01. Todos os serviços da arquitetura precisam estar na mesma região.

Decisão. AWS, região sa-east-1 (São Paulo), para todos os ambientes em nuvem.

Alternativas descartadas.

Alternativa	Por que não
Região dos EUA (us-east-1), mais barata	Dados pessoais fora do país pedem salvaguardas de transferência internacional na LGPD (art. 33) e somam latência de ida e volta a cada requisição
Outra nuvem com região em São Paulo (GCP ou Azure)	Também atenderia à latência. Ficamos com a AWS porque todos os serviços escolhidos (Fargate, RDS PostgreSQL Multi-AZ, Polly, WAF, Secrets Manager) existem na região de São Paulo e têm preço publicado na tabela oficial, que o script do Bloco 1 consulta para recalcular o custo a cada mudança

Consequências. Preço mais alto que nos EUA, já refletido no custo do Bloco 1.

3.3 Stack tecnológica

Todas as camadas, cada uma com a escolha, a alternativa descartada e o motivo técnico, ligado ao requisito ou ao ADR de onde veio.

Camada	Escolha	Alternativa descartada	Motivo técnico
App mobile	React Native 0.8x com Expo SDK, TypeScript	Flutter	Componentes nativos lidos pelo TalkBack e VoiceOver sem anotação extra (RNF09). Mesma linguagem da API (ADR-005)
Armazenamento seguro no celular	Expo SecureStore (Keystore no Android, Keychain no iOS)	AsyncStorage	Token e chave do aparelho precisam de armazenamento cifrado pelo sistema (RNF05, ADR-010)
Biometria	expo-local-authentication	Biometria própria	A biometria nativa não tira o dado do celular. Nada biométrico chega ao servidor (risco R08)
Leitura de boleto	expo-camera com leitura de código de barras	Biblioteca de terceiros paga	Lê o padrão ITF dos boletos sem custo por leitura (RF013)
Painéis internos	React 19 com Vite, TypeScript	Next.js	Painel interno não precisa de renderização no servidor nem de SEO. Arquivos estáticos servidos pela API (ADR-012)
API	Node.js 22 LTS, NestJS 11, TypeScript estrito	Java 21 com Spring Boot	Cabe em 1 GB por tarefa, mesma linguagem do app, módulos com injeção de dependência (ADR-004)
Validação de entrada	class-validator com DTOs do NestJS	Validação manual	Toda entrada validada antes do domínio, que é o item A03 (injeção) da OWASP
Acesso a dados	Kysely (construtor de SQL tipado) com SQL explícito	ORM completo (TypeORM ou Prisma)	O razão contábil usa gatilho, `SELECT ... FOR UPDATE` e `SKIP LOCKED` (ADR-007, ADR-008). SQL explícito evita consulta escondida pelo ORM e deixa o p95 previsível (RNF01)
Migrações	Arquivos SQL versionados executados pelo node-pg-migrate	Migração automática do ORM	Migração revisada linha a linha e no padrão expandir e contrair, sem parar o sistema (Bloco 5)
Banco de dados	PostgreSQL 17 no Amazon RDS Multi-AZ	MongoDB	Transação ACID entre várias linhas, chave estrangeira e restrição (RNF11, ADR-006, Bloco 5)
Fila de eventos	Tabela outbox no PostgreSQL e worker	Amazon SQS	Gravar o dado e o evento na mesma transação (ADR-008)
Voz	Amazon Polly e cache no S3	Só a voz do celular	Mesma voz em todos os aparelhos (ADR-011)
Notificação push	Expo Push (sobre FCM e APNs)	Amazon SNS mobile push	Já integrado ao Expo, sem custo por mensagem
Autenticação	Módulo próprio: Argon2id, JWT de 15 min, renovação de 30 dias, chave do aparelho	Amazon Cognito	Vínculo de um único aparelho e regras de menor e responsável (ADR-010)
Log	pino com saída em JSON para o CloudWatch Logs	Log em texto livre	Log estruturado com identificador de correlação em 100% das requisições (RNF13)
Containers	Docker com build em múltiplos estágios	Imagem única com ferramentas de build	Imagem final menor e sem compilador, menos superfície de ataque (RNF06)
Execução na nuvem	Amazon ECS com Fargate	Kubernetes (EKS)	Sem custo de plano de controle e sem operar cluster (ADR-009)

Camada	Escolha	Alternativa descartada	Motivo técnico
Rede e borda	Application Load Balancer com AWS WAF	Exposição direta das tarefas	TLS na borda, distribuição entre 2 zonas (RNF03) e regras contra ataques comuns (R02)
Segredos	AWS Secrets Manager	Variável de ambiente no código	Segredo fora do repositório, com rotação (R02)
Infraestrutura como código	Terraform	Criar recursos pelo console	Ambientes reproduzíveis e revisados em pull request. Homologação e produção com o mesmo código
CI/CD	GitHub Actions	Jenkins	O código já está no GitHub e não há servidor de CI para manter
Testes	Jest (unidade e integração), Testcontainers (PostgreSQL real), Maestro (E2E mobile), k6 (carga)	Mock do banco em todos os testes	O razão e o outbox só são testados de verdade contra um PostgreSQL real (Bloco 9)
Desenvolvimento local	Docker Compose	Ambiente compartilhado na nuvem	Custo zero de desenvolvimento (Bloco 1) e cada dev com o próprio banco

3.4 Padrões de design

Quais padrões o Rufus aplica, onde e por quê. No fim, os padrões que avaliamos e **não** aplicamos, também com o motivo.

Aplicados

Padrão	Onde	Por quê
Monolito modular	Estrutura da API: módulos `identidade`, `contas`, `pagamentos`, `familia`, `antifraude`, `atendimento`, `notificacao`, `backoffice`	Fronteiras claras sem o custo de microsserviços (ADR-001)
Portas e Adaptadores (hexagonal)	`PortaBancaria`, `PortaVoz`, `PortaNotificacao`, `PortaIdentidade`, cada uma com adaptador real e falso	Trocar de parceiro BaaS sem tocar no domínio (R04, ADR-002) e rodar tudo no localhost
Adapter (camada anticorrupção)	`AdaptadorBaasHttp` traduz o modelo do parceiro para `Transacao` e `Conta`	O modelo do fornecedor não vaza para o domínio
Repository	Um repositório por agregado: `ContaRepository`, `TransacaoRepository`, `ChamadoRepository`	O domínio não conhece SQL. Nos testes de unidade o repositório é trocado por um em memória
Unit of Work	`UnidadeDeTrabalho` abre a transação do banco e passa os repositórios para o caso de uso	Pix, lançamentos e evento do outbox gravados juntos ou nada (RNF11)
Transactional Outbox	Tabela `outbox_evento` gravada na mesma transação, lida pelo worker	Evento nunca perdido nem enviado sem o dado gravado (ADR-008)
Saga orquestrada	Envio de Pix: reservar saldo, enviar ao parceiro, confirmar ou compensar (estorno da reserva)	A operação envolve um sistema externo que pode falhar no meio. A compensação devolve o dinheiro ao cliente (diagrama de sequência do erro crítico, Bloco 4)
Idempotency Key	Cabeçalho `Idempotency-Key` em `POST /v1/pix/envios` e `POST /v1/boletos/pagamentos`, com restrição única no banco	Zero Pix duplicado (RNF11, US07)
State	Ciclo de vida de `Transacao`: PENDENTE, RETIDA, ENVIADA, CONCLUIDA, RECUSADA, ESTORNADA	Cada estado define quais transições são válidas. Impede, por exemplo, estornar um Pix já recusado
Strategy	Regras do antifraude (`RegraDestinatarioNovo`, `RegraHorarioNoturno`, `RegraValorForaDoPadrao`) implementam `RegraRisco`	Regra nova entra sem mexer no motor. Cada regra é testada sozinha
Factory	`FabricaDeConta` cria conta de titular ou de menor, já com limites e vínculo corretos	Conta de menor tem regras diferentes (RF014, RF015) e não pode nascer sem vínculo
Domain Events (Observer)	`PixConcluido`, `ContaBloqueada`, `PedidoAprovacaoCriado` publicados no outbox	Notificação, contato de confiança e responsável reagem sem que o módulo de pagamentos conheça cada um
Circuit Breaker com nova tentativa	Chamadas ao parceiro BaaS e ao Polly	Se o parceiro cair, a API para de insistir por 30 s, responde rápido ao cliente e não esgota as conexões (RNF02)

Avaliados e não aplicados

Padrão	Por que não agora
CQRS com banco de leitura separado	A leitura (saldo e extrato) cabe no p95 de 300 ms com índice e saldo de fechamento diário. Um segundo banco aumentaria custo e criaria atraso entre escrita e leitura, ruim para quem confere o saldo logo depois do Pix
Event Sourcing completo	O razão com partidas dobradas (ADR-007) já guarda o histórico do dinheiro. Reconstruir todo o estado a partir de eventos traria complexidade sem requisito que peça
Saga coreografada	Com um fluxo central (Pix) e poucos participantes, a saga orquestrada deixa o passo a passo visível num lugar só, mais fácil de testar e de explicar

3.5 Modelo de domínio (fonte única)

Este arquivo é a **fonte única** das entidades, atributos, tipos e relações do Rufus. O diagrama de classes (Bloco 4), o banco de dados (Bloco 5), o contrato OpenAPI (Bloco 8) e o glossário (Bloco 9) seguem exatamente estes nomes. Mudou aqui, muda lá.

Convenções: nomes de classe em PascalCase e de atributo em camelCase no código; no banco, tabelas e colunas em snake_case com os mesmos nomes. Dinheiro sempre em centavos inteiros (`valorCentavos: Long` , `bigint` no banco). Identificadores são `UUID` . Datas e horas em `Instant` (UTC, `timestamptz`).

Módulos e entidades

Módulo	Entidades que ele é dono (só ele escreve)
identidade	Cliente, Dispositivo, Credencial, SessaoRenovacao, Consentimento
contas	Conta, Carteira, Lancamento
pagamentos	Transacao (e subtipos PixEnvio, PixRecebimento, PagamentoBoleto, MovimentoMeta), ChavePix, Meta
familia	VinculoResponsavel, PedidoAprovacao, ContatoConfianca
antifraude	AnaliseRisco
atendimento	Chamado, MensagemChamado
backoffice	Funcionario, RegistroAuditoria
notificacao	Notificacao, OutboxEvento, LembreteConta

Entidades

Cliente (identidade)

Atributo	Tipo	Regra
id	UUID	
nomeCompleto	String	
cpf	Cpf	Único. Cifrado em repouso, com hash para busca. PII
dataNascimento	LocalDate	Cifrado. PII
celular	String	PII
email	String	Opcional. PII
tipo	TipoCliente	TITULAR ou MENOR
status	StatusCliente	EM_ANALISE, ATIVO, BLOQUEADO, ENCERRADO
criadoEm	Instant	

Dispositivo (identidade)

Atributo	Tipo	Regra
id	UUID	
clienteId	UUID	Só 1 ativo por cliente (RF005)
modelo	String	

Atributo	Tipo	Regra
chavePublica	String	Chave gerada no Keystore/Keychain (ADR-010)
ativo	Boolean	
vinculadoEm	Instant	

Credencial (identidade)

`clienteId: UUID` (1 para 1 com Cliente), `hashSenha: String` (Argon2id), `tentativasErradas: Integer`, `bloqueadaAte: Instant` (opcional).

SessaoRenovacao (identidade)

`id: UUID`, `dispositivoId: UUID`, `hashToken: String`, `expiraEm: Instant`, `revogadaEm: Instant` (opcional).

Consentimento (identidade)

`id: UUID`, `clienteId: UUID`, `tipo: TipoConsentimento` (TERMOS_DE_USO, PRIVACIDADE, BIOMETRIA, RESPONSAVEL_LEGAL), `versaoTermo: String`, `aceitoEm: Instant`, `aceitoPorClienteId: UUID` (o próprio ou o responsável).

Conta (contas)

Atributo	Tipo	Regra
id	UUID	
clienteId	UUID	1 conta por cliente
agencia	String	Dado do parceiro
numero	String	Único
idContaParceiro	String	Identificador no parceiro BaaS
status	StatusConta	ATIVA, BLOQUEADA_TOTAL, ENCERRADA
bloqueadaEm	Instant	Opcional. Preenchido pelo "bloquear tudo agora" (RF020)
criadaEm	Instant	

Carteira (contas)

`id: UUID`, `contaId: UUID` (vazio nas carteiras técnicas), `tipo: TipoCarteira` (PRINCIPAL, META, LIQUIDACAO_PIX, LIQUIDACAO_BOLETO). Toda conta tem 1 carteira PRINCIPAL e 1 carteira META por meta. As carteiras de liquidação são do sistema e representam o dinheiro em trânsito com o parceiro.

Lancamento (contas)

`id: UUID`, `transacaoId: UUID`, `carteiraId: UUID`, `valorCentavos: Long` (positivo = crédito, negativo = débito, nunca zero), `criadoEm: Instant`. **A soma dos lançamentos de uma transação é sempre zero** (ADR-007). Saldo da carteira = soma dos seus lançamentos.

Transacao (pagamentos), classe abstrata

Atributo	Tipo	Regra
id	UUID	
contaId	UUID	
tipo	TipoTransacao	PIX_ENVIO, PIX_RECEBIMENTO, BOLETO, META_GUARDAR, META_RESGATAR

Atributo	Tipo	Regra
valorCentavos	Long	Maior que zero
status	StatusTransacao	PENDENTE, RETIDA, ENVIADA, CONCLUIDA, RECUSADA, ESTORNADA
chaveIdempotencia	String	Única por conta (RNF11)
idParceiro	String	Opcional. Identificador fim a fim no parceiro
criadaEm	Instant	
concluidaEm	Instant	Opcional

Subtipos (herança, porque um Pix **é uma** transação e compartilha o ciclo de vida e os lançamentos): - **PixEnvio**: `chaveDestino: String`, `nomeRecebedor: String`, `documentoRecebedorMascarado: String`, `bancoRecebedor: String`, `destinatarioNovo: Boolean`. - **PixRecebimento**: `nomePagador: String`, `bancoPagador: String`. - **PagamentoBoleto**: `linhaDigitavel: String`, `beneficiario: String`, `vencimento: LocalDate`, `jurosCentavos: Long`. - **MovimentoMeta**: `metaId: UUID`.

ChavePix (pagamentos)

`id: UUID`, `contaId: UUID`, `tipo: TipoChavePix` (CPF, CELULAR, ALEATORIA), `valor: String` (único), `status: StatusChavePix` (ATIVA, EXCLUIDA), `criadaEm: Instant`.

Meta (pagamentos)

`id: UUID`, `contaId: UUID`, `carteiraId: UUID` (a carteira META, criada junto, composição), `nome: String`, `valorAlvoCentavos: Long`, `dataAlvo: LocalDate`, `imagemUrl: String`, `status: StatusMeta` (ATIVA, CONCLUIDA, CANCELADA).

VinculoResponsavel (familia)

`id: UUID`, `menorClienteId: UUID` (único), `responsavelClienteId: UUID`, `status: StatusVinculo` (CONVIDADO, ATIVO, ENCERRADO), `limiteDiarioCentavos: Long`, `limiteMensalCentavos: Long`, `convidadoEm: Instant`, `aceitoEm: Instant`, `expiraEm: Instant` (convite vale 7 dias, US09).

PedidoAprovacao (familia)

`id: UUID`, `vinculoId: UUID`, `transacaoId: UUID`, `status: StatusPedido` (PENDENTE, APROVADO, RECUSADO, EXPIRADO), `criadoEm: Instant`, `expiraEm: Instant` (24 horas, US18), `decididoEm: Instant`.

ContatoConfianca (familia)

`id: UUID`, `clienteId: UUID`, `nome: String` (PII), `celular: String` (PII), `status: StatusContato` (CONVIDADO, ATIVO, REMOVIDO), `aceitoEm: Instant`.

AnaliseRisco (antifraude)

`id: UUID`, `transacaoId: UUID` (1 para 1), `nota: Integer` (0 a 100), `motivos: List<String>`, `resultado: ResultadoAnalise` (LIBERADA_AUTOMATICA, RETIDA, LIBERADA_ANALISTA, RECUSADA_ANALISTA), `analistaId: UUID` (opcional), `decididaEm: Instant`. Pix com nota **igual ou acima de 70** fica RETIDA (RF026).

Chamado (atendimento)

`id: UUID`, `clienteId: UUID`, `atendenteId: UUID` (opcional), `assunto: String`, `status: StatusChamado` (ABERTO, EM_ATENDIMENTO, RESOLVIDO), `abertoEm: Instant`, `fechadoEm: Instant`.

MensagemChamado (atendimento)

`id: UUID`, `chamadoId: UUID`, `autor: AutorMensagem` (CLIENTE, ATENDENTE), `texto: String`, `audioUrl: String` (opcional), `enviadaEm: Instant`. Composição: a mensagem não existe sem o chamado.

Funcionario (backoffice)

`id: UUID`, `nome: String`, `email: String` (único), `papel: Papel` (ATENDENTE, ANALISTA_ANTIFRAUDE, ADMINISTRADOR), `hashSenha: String`, `segredoTotp: String` (cifrado), `ativo: Boolean`.

RegistroAuditoria (backoffice)

`id: Long`, `funcionarioId: UUID`, `acao: String`, `entidade: String`, `entidadeId: String`, `ip: String`, `ocorridoEm: Instant`. Só inserção, nunca alteração. Guardado 5 anos (RNF14).

Notificacao (notificacao)

`id: UUID`, `clienteId: UUID`, `canal: Canal` (PUSH, SMS), `tipo: String`, `conteudo: String`, `status: StatusNotificacao` (PENDENTE, ENVIADA, FALHOU), `criadaEm: Instant`, `enviadaEm: Instant`.

OutboxEvento (notificacao, usado por todos)

`id: Long`, `tipo: String` (ex.: `PixConcluido`), `agregadoId: UUID`, `payload: Json`, `criadoEm: Instant`, `processadoEm: Instant` (opcional), `tentativas: Integer`, `proximaTentativaEm: Instant`.

LembreteConta (notificacao)

`id: UUID`, `clienteId: UUID`, `descricao: String`, `diaVencimento: Integer` (1 a 31), `ativo: Boolean`.

Relações

De	Para	Cardinalidade	Tipo	Por quê
Cliente	Conta	1 para 1	Associação	Uma conta por cliente no MVP
Cliente	Dispositivo	1 para N (1 ativo)	Composição	Dispositivo não existe sem o cliente
Cliente	Credencial	1 para 1	Composição	
Cliente	Consentimento	1 para N	Composição	
Conta	Carteira	1 para N	Composição	Carteira não existe sem a conta
Carteira	Lancamento	1 para N	Associação	
Transacao	Lancamento	1 para N (no mínimo 2)	Composição	Lançamentos nascem e morrem com a transação
Conta	Transacao	1 para N	Associação	
Transacao	PixEnvio, PixRecebimento, PagamentoBoleto, MovimentoMeta	Generalização	Herança	Mesmo ciclo de vida (State) e mesmos lançamentos
Conta	ChavePix	1 para N	Agregação	A chave pode ser excluída sem afetar a conta
Conta	Meta	1 para N	Associação	
Meta	Carteira	1 para 1	Composição	A carteira da meta nasce com a meta

De	Para	Cardinalidade	Tipo	Por quê
Cliente (menor)	VinculoResponsavel	1 para 1	Associação	Um responsável vinculado por menor no MVP
Cliente (responsável)	VinculoResponsavel	1 para N	Associação	Um pai pode ter mais de um filho
VinculoResponsavel	PedidoAprovacao	1 para N	Composição	
Cliente	ContatoConfianca	1 para N	Composição	
Transacao	AnaliseRisco	1 para 0..1	Associação	Só Pix enviado é analisado
Funcionario	AnaliseRisco	1 para N	Associação	Quem decidiu
Cliente	Chamado	1 para N	Associação	
Chamado	MensagemChamado	1 para N	Composição	
Funcionario	RegistroAuditoria	1 para N	Associação	

Classes de serviço (para o diagrama de classes e o C4 nível 4)

Classe	Métodos principais
ServicoEnvioPix	`+iniciar(contaId: UUID, pedido: PedidoPix, chaveIdempotencia: String): Transacao`, `+confirmarRetorno(idParceiro: String, aceito: Boolean): void`, `-reservarSaldo(t: Transacao): void`, `-compensar(t: Transacao): void`
MotorAntifraude	`+avaliar(t: PixEnvio): AnaliseRisco` (soma as notas das `RegraRisco`)
RegraRisco (interface)	`+pontuar(t: PixEnvio, h: HistoricoCliente): Integer`
PortaBancaria (interface)	`+consultarChave(chave: String): DadosRecebedor`, `+enviarPix(t: PixEnvio): RespostaParceiro`, `+pagarBoleto(b: PagamentoBoleto): RespostaParceiro`
PortaVoz (interface)	`+falar(texto: String): UrlAudio`
UnidadeDeTrabalho	`+executar<T>(trabalho: Funcao<T>): T`

3.6 Rotas da API (fonte única)

Lista canônica das rotas. O contrato completo, com corpos de requisição e resposta, está em OpenAPI 3.0 no Bloco 8 (`bloco-8-dev/openapi.yaml`), que segue esta lista. Os diagramas de sequência (Bloco 4) usam estes mesmos caminhos.

Base: `https://api.rufusbank.com.br/v1` em produção, `http://localhost:3000/v1` no desenvolvimento. Todas as rotas, exceto as marcadas como públicas, exigem `Authorization: Bearer <token de acesso>`.

Método	Rota	Módulo	RF	Observação
POST	/onboarding/cadastros	identidade	RF001	Pública. Inicia o cadastro
POST	/onboarding/cadastros/{id}/documentos	identidade	RF001	Pública com token do cadastro. Foto do documento
POST	/onboarding/cadastros/{id}/selfie	identidade	RF001, RF002	Envia a selfie e dispara a validação no parceiro
GET	/onboarding/cadastros/{id}	identidade	RF002	Situação do cadastro
POST	/auth/login	identidade	RF003, RF004	Pública. CPF, senha e assinatura do aparelho
POST	/auth/renovacao	identidade	RNF05	Pública com token de renovação. Troca o token
POST	/auth/logout	identidade		Revoga a sessão
POST	/dispositivos/troca	identidade	RF005	Selfie nova para trocar de aparelho
GET	/contas/me	contas	RF006	Dados da conta
GET	/contas/me/saldo	contas	RF006	Saldo da carteira principal
GET	/contas/me/extrato	contas	RF006	Paginado por cursor
POST	/contas/me/bloqueio-total	contas	RF020	"Bloquear tudo agora"
DELETE	/contas/me/bloqueio-total	contas	RF020	Desbloqueio com selfie e 1 hora de espera
POST	/pix/consultas-chave	pagamentos	RF009	Devolve nome do recebedor e banco
POST	/pix/envios	pagamentos	RF008, RF019	Exige `Idempotency-Key`
GET	/pix/envios/{id}	pagamentos	RF008	Situação do Pix
GET	/pix/envios/{id}/comprovante	pagamentos	RF012	
POST	/pix/cobrancas	pagamentos	RF010	Gera QR Code para receber
GET	/pix/chaves	pagamentos	RF011	
POST	/pix/chaves	pagamentos	RF011	
DELETE	/pix/chaves/{id}	pagamentos	RF011	
POST	/boletos/consultas	pagamentos	RF013	Lê a linha digitável e devolve beneficiário, valor e vencimento
POST	/boletos/pagamentos	pagamentos	RF013	Exige `Idempotency-Key`
GET	/metas	pagamentos	RF017	
POST	/metas	pagamentos	RF017	
POST	/metas/{id}/depositos	pagamentos	RF017	Exige `Idempotency-Key`
POST	/metas/{id}/resgates	pagamentos	RF017	Exige `Idempotency-Key`

Método	Rota	Módulo	RF	Observação
POST	/familia/convites-responsavel	familia	RF014	O menor convida o responsável
POST	/familia/vinculos/{id}/aceite	familia	RF014	O responsável aceita
PUT	/familia/vinculos/{id}/limites	familia	RF015	Só o responsável
POST	/familia/pedidos-aprovacao	familia	RF016	O menor pede
POST	/familia/pedidos-aprovacao/{id}/decisao	familia	RF016	O responsável decide
POST	/contatos-confianca	familia	RF018	
DELETE	/contatos-confianca/{id}	familia	RF018	
POST	/falas	notificacao	RF007	Texto para áudio. Devolve URL do áudio
POST	/lembretes	notificacao	RF022	
POST	/chamados	atendimento	RF024	
GET	/chamados/{id}/mensagens	atendimento	RF024	
POST	/chamados/{id}/mensagens	atendimento	RF024	
POST	/titular/exportacoes	identidade	RF029	Gera arquivo com os dados do titular
POST	/titular/encerramento	identidade	RF029	
POST	/webhooks/baas	pagamentos	RF010, RF008	Pública, com assinatura HMAC do parceiro
POST	/admin/auth/login	backoffice	RF030	Pública. Senha e TOTP
GET	/admin/analises	antifraude	RF027	Papel ANALISTA_ANTIFRAUDE
POST	/admin/analises/{id}/decisao	antifraude	RF027	Papel ANALISTA_ANTIFRAUDE
GET	/admin/chamados	atendimento	RF025	Papel ATENDENTE
POST	/admin/chamados/{id}/mensagens	atendimento	RF025	Papel ATENDENTE
GET	/admin/clientes/{id}/historico	atendimento	RF025	Papel ATENDENTE. Gera registro de auditoria
POST	/admin/funcionarios	backoffice	RF030	Papel ADMINISTRADOR
GET	/health		RNF03	Pública. Usada pelo balanceador e pela verificação externa

Portas: a API escuta na **3000** dentro do container. O balanceador recebe na **443** (HTTPS) e redireciona a 80 para 443. O PostgreSQL usa a **5432**, acessível só de dentro da VPC.